

Introduction to Web Technologies

Web Security
Juraj Somorovsky

Summer Semester 2024
Paderborn University

SICP Students' Day

Career event for jobs, internships and thesis topics
organized by Paderborn University and local companies

Get in touch with:



arvato BHTC

CLAAS



dSPACE

finanz informatik

GOLDBECK

HÖRMANN
Toren · Türen · Zargen · Antriebe

meta
morphosis

myc myconsult

NTT DATA

OPTANO
a KEARNEY company

PHENIX
CONTACT

Safety is for life.™

S&N
INVENT

Skyhigh
security



Weidmüller

UNITY
CONFLICTING & INNOVATION



April 16 from 2:30 – 6:30 p.m.



Zukunftsmeile 2 (ZM2)

No registration required!

More infos:



or sicp.de/en/event



Demonstrators



Company Pitches



Job-Wall



Drinks & Fingerfood

Studying abroad

- **Information events:**

26.03.2024, 13-14 Uhr

11.04.2024, 13-14 Uhr

15.04.2024, 13-14 Uhr (Engl.)

25.04.2024, 13-14 Uhr

07.05.2024, 13-14 Uhr

Webseite des International Office: go.upb.de/outgoingberatung

CHE Ranking

- You received an email about CHE ranking
- Please help us and fill out the questionnaires

CHE Ranking



The most comprehensive and detailed ranking of German universities and universities of applied sciences

The CHE University Ranking contains facts on university study, teaching, equipment and research, as well as students' opinions on study conditions at their HEI, and, for some subjects, how professors view the reputation of departments. In addition to comparative criteria, prospective students have a wealth of descriptive characteristics on academic programmes and teaching at their disposal. View the results at www.university-ranking.de.



Methodology

The CHE University Ranking is based on methodological standards, setting it apart from other rankings in the German and English-speaking world in essential respects. [Find out more about the methodology](#)



Advisory committees of the CHE University Ranking

The CHE University Ranking team is supported by a Coordinators' Advisory Committee, a Subject Advisory Committee and a Scientific Advisory Board. [Find out more about the advisory committees](#)



Video: Was ist das CHE Hochschulranking?

ZEIT ONLINE FÜR HOCHSCHULEN

Hey Studium Studium ▾ Orte ▾ Interessentest Ranking Studienführer Anmelden 🔍

☐ **Karlsruher Inst. f. Technologie KIT**
Fakultät für Informatik 2740 Baden-Württemberg

Allgemeine Studiensituation
★★★★☆

Unterstützung am Studienanfang
🕒 13/14 Punkten

Forschungsgelder pro Wissenschaftler:in
€ 107.700

Betreuung durch Lehrende
★★★★☆

Studiengänge anzeigen ▾

☐ **TU München/Garching**
Fakultät für Informatik 4200 Bayern

Allgemeine Studiensituation
★★★★☆

Unterstützung am Studienanfang
🕒 11/14 Punkten

Forschungsgelder pro Wissenschaftler:in
€ 126.300

Betreuung durch Lehrende
★★★★☆

Studiengänge anzeigen ▾

☐ **Uni Paderborn**
Fakultät für Elektrotechnik, Informatik und Mathematik 1770 Nordrhein-Westfalen

Allgemeine Studiensituation
★★★★☆

Unterstützung am Studienanfang
🕒 12/14 Punkten

Forschungsgelder pro Wissenschaftler:in
€ 107.900

Betreuung durch Lehrende
★★★★☆

In top 10 according to the last poll.

Introduction to Web Technologies

Web Security
Juraj Somorovsky

Summer Semester 2024
Paderborn University

Motivation

- Every company, bank, institution has a web application
 - ecommerce, online banking, advertisements
 - email, admin interfaces, web services
 - Social networks
- vulnerabilities can be used to reveal sensitive data, steal logins

From hacking Myspace (2005) to

Web sites threatened by Samy worm

The newly discovered Samy worm is the first to exploit a cross site scripting vulnerability, prompting security experts to fear the technique could be used to open a new front in the war against malware. Samy is a self-propagating worm that was written by a member of MySpace.

By Munir Kotadia | October 17, 2005 -- 06:37 GMT (07:37 BST) | Topic: Security



The newly discovered Samy worm is the first to exploit a cross site scripting vulnerability, prompting security experts to fear the technique could be used to open a new front in the war against malware.

Samy is a self-propagating worm that was written by a member of MySpace.com, which is a community site dedicated to helping friends stay in touch and share pictures etc. The worm exploited vulnerabilities in the MySpace.com site to add 1 million users to the author's "friends" list.

<https://www.zdnet.com/article/web-sites-threatened-by-samy-worm/>
<https://samy.pl/myspace/>

Firefox

marks Tools Help

http://mail.myspace.com/index.cfm?fuseaction=mail.friendRequests&Mytoken=

MySpace.com | Home The Web MySpace Search Help | SignOut

classmates-com

I graduated in:

State: MD Year: 90 GO!

Springfield High (1084) Martin Luther King High (676) Trinity High School (328) NEW YORK High School (820)

Home | Browse | Search | Invite | Rank | Mail | Blog | Favorites | Forum | Groups | Events | Games | Music | Classifieds

KICK ASS

Mail Center

I RULE

Friend Request Manager

Approve or Deny Your Friend Requests Here [help]

Listing 1-10 of 919664 1 2 3 4 5 >> of 91967 Next >

Date:	From:	Confirmation:
☐ Oct 4, 2005 10:22 PM		PLEASE DONT PRESS CHARGES Lulu the Loveable Freak wants to be your friend! Approve Deny Send Message
☐ Oct 4, 2005 10:21 PM		AlysOn!! wants to be your friend! Approve Deny Send Message
☐ Oct 4, 2005 10:20 PM		Erika wants to be your friend! Approve Deny Send Message

Online Now!

Fly Fishing Trip in Mexico
All inclusive package in Ascension Bay, Mexico, from US\$1,600...
www.pescamaya.com

Yellow Dog Flyfishing Adventures
Specializing in destination angling packages throughout the U...
www.yellowdogfly...

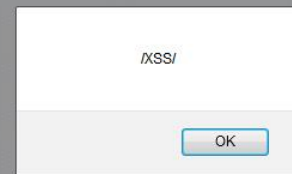
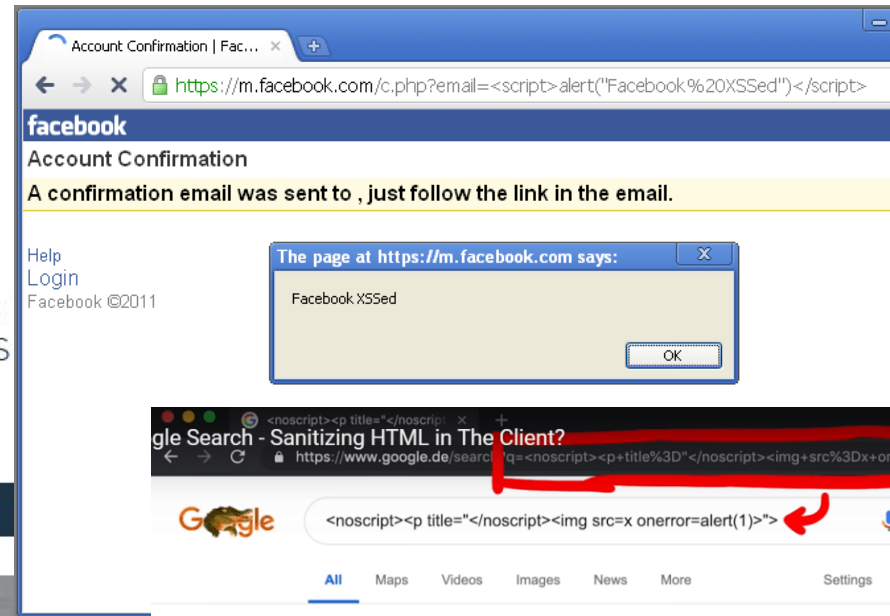
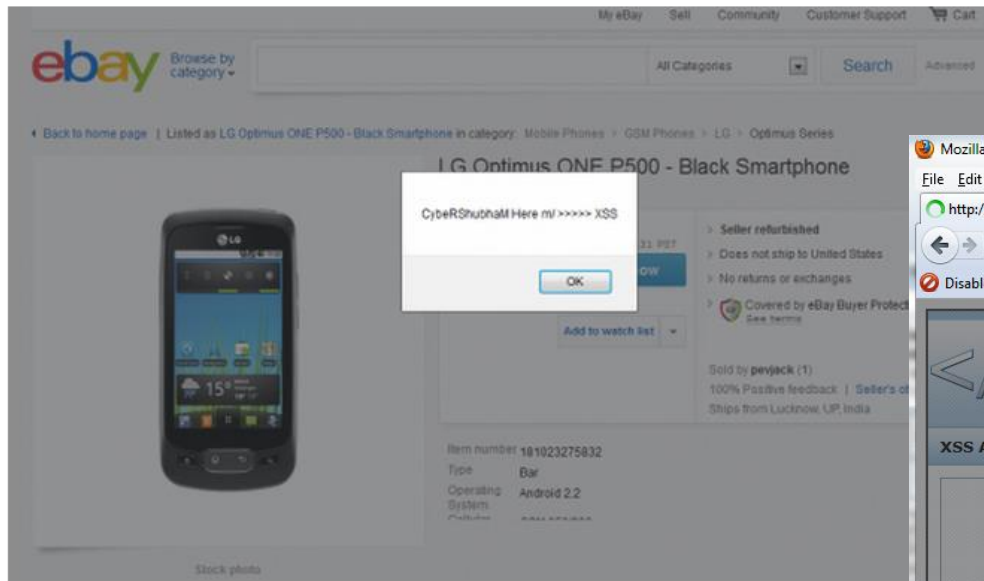
Elk River Guiding

...to hacking eBay, Facebook, or Google

Active XSS flaw discovered

According to XSSed, Shubham Upadhyay has discovered an active XSS

By Dancho Danchev for Zero Day | November 16, 2012 -- 23:23 GMT (23:23 GMT) | Topic: Security



Goals

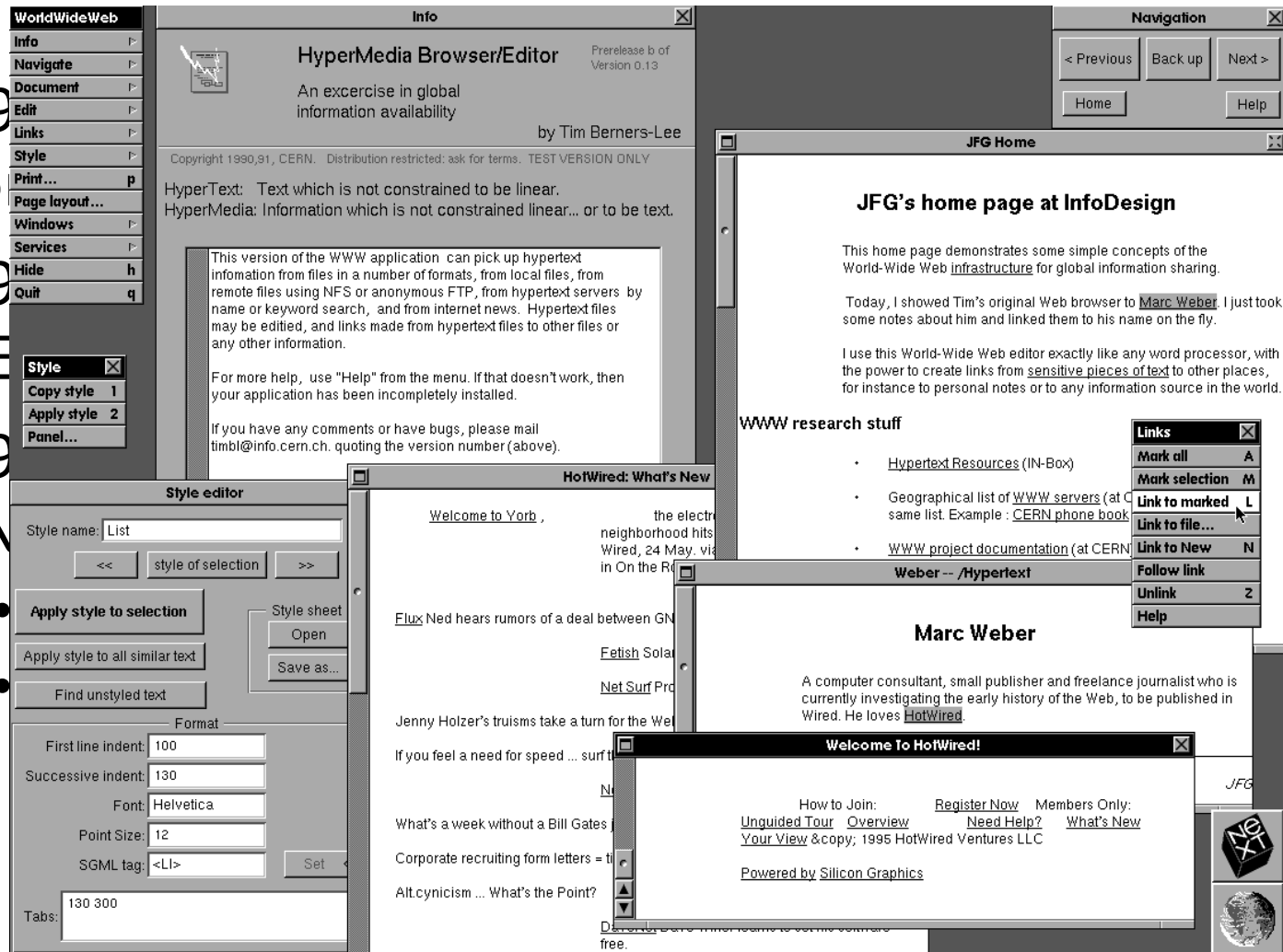
- Understanding web security
- Basic HTML, Javascript, DOM
- Security Features
- Attacks
- Countermeasures and Best Practices

HTTP and WWW: History

- 1980: Tim Berners-Lee writes a notebook program for CERN, "Enquire-Within-Upon-Everything"
- 1989: Tim Berners-Lee writes "HyperText and CERN"
- 1990: Tim Berners-Lee writes the first web browser "NeXTSTEP"
 - First Website
 - Project called World Wide Web

HTTP and WWW: History

- 1990 for
- 1991 CE
- 1991 “N



m

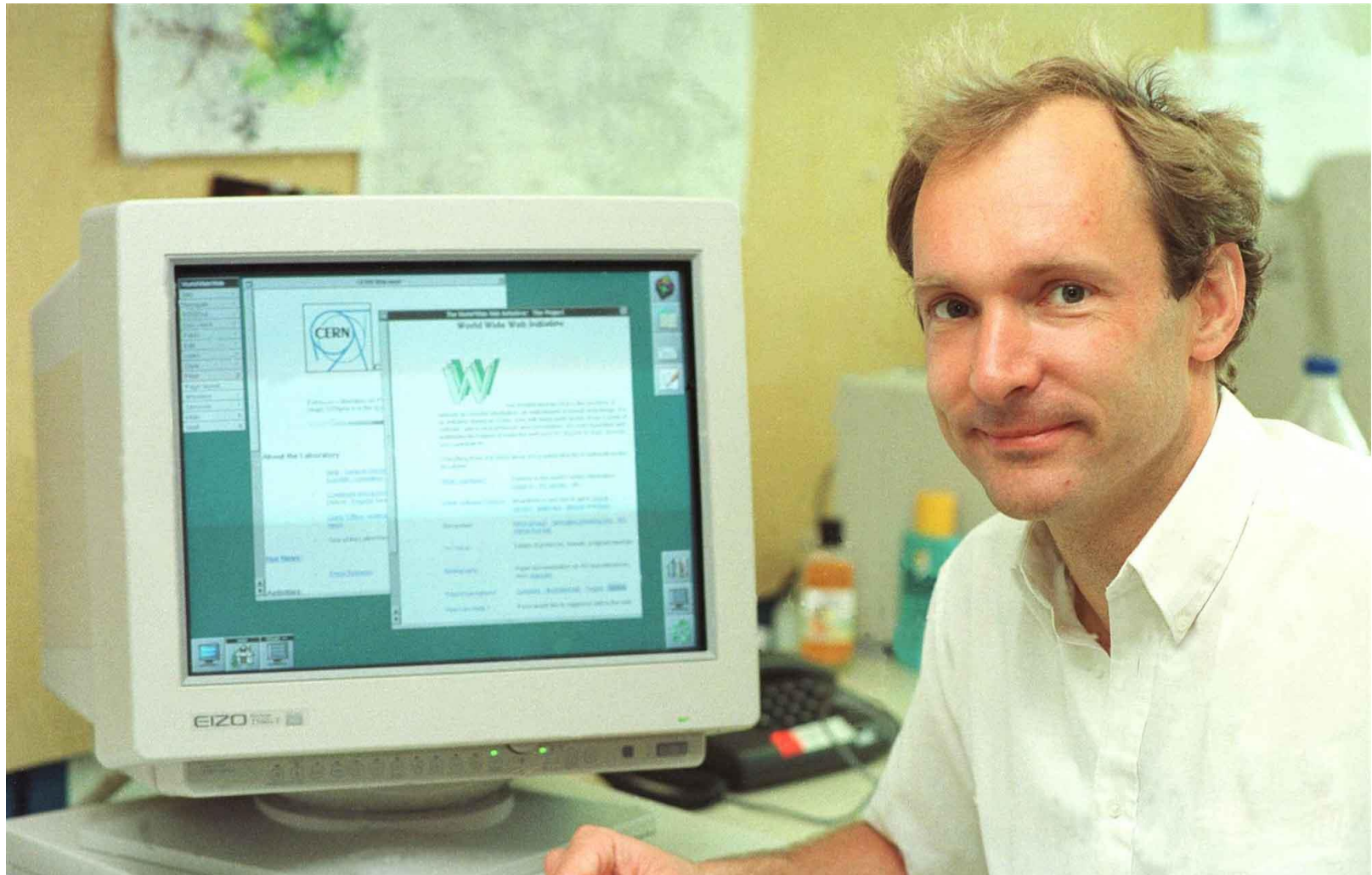
ser

Hypertext Transfer Protocol (HTTP)

- For accessing websites: HTTP/0.9 developed
 - Only GET methods supported
 - No headers
- Standardized in 1996 as RFC 1945: HTTP/1.0
- Current versions:
 - HTTP/1.1
 - HTTP/2.0 (since 2015)
 - HTTP/3 (2020, based on UDP)

Application
Transport
Internet
Network

Sir Tim Berners-Lee



And the winner of the 'Modest Job title' goes to this chap.

Introducing Web Platform Docs

Share

More info



Tim Berners-Lee
Web Developer

▶ 🔊 1:32 / 1:51

CC ⚙ ⌚

YouTube

⌵ ⌵ ⌵

Hypertext Transfer Protocol



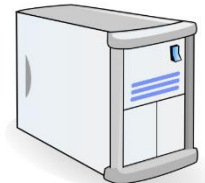
GET /History.html HTTP/1.1



HTTP/1.1 200 OK

...

...



www.w3.org

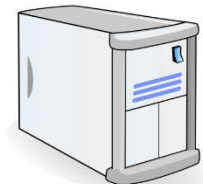
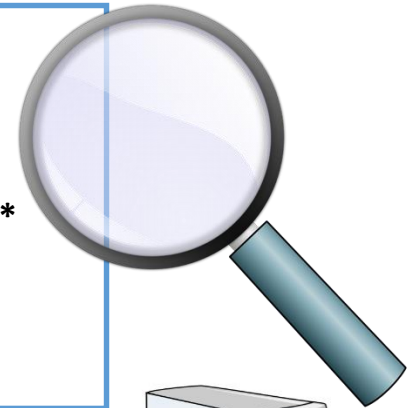
HTTP Header Fields

Human Dog
readable



Human Dog
readable

```
GET /History.html HTTP/1.1
Host: www.w3.org
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:66.0)
Gecko/20100101 Firefox/66.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
....
```



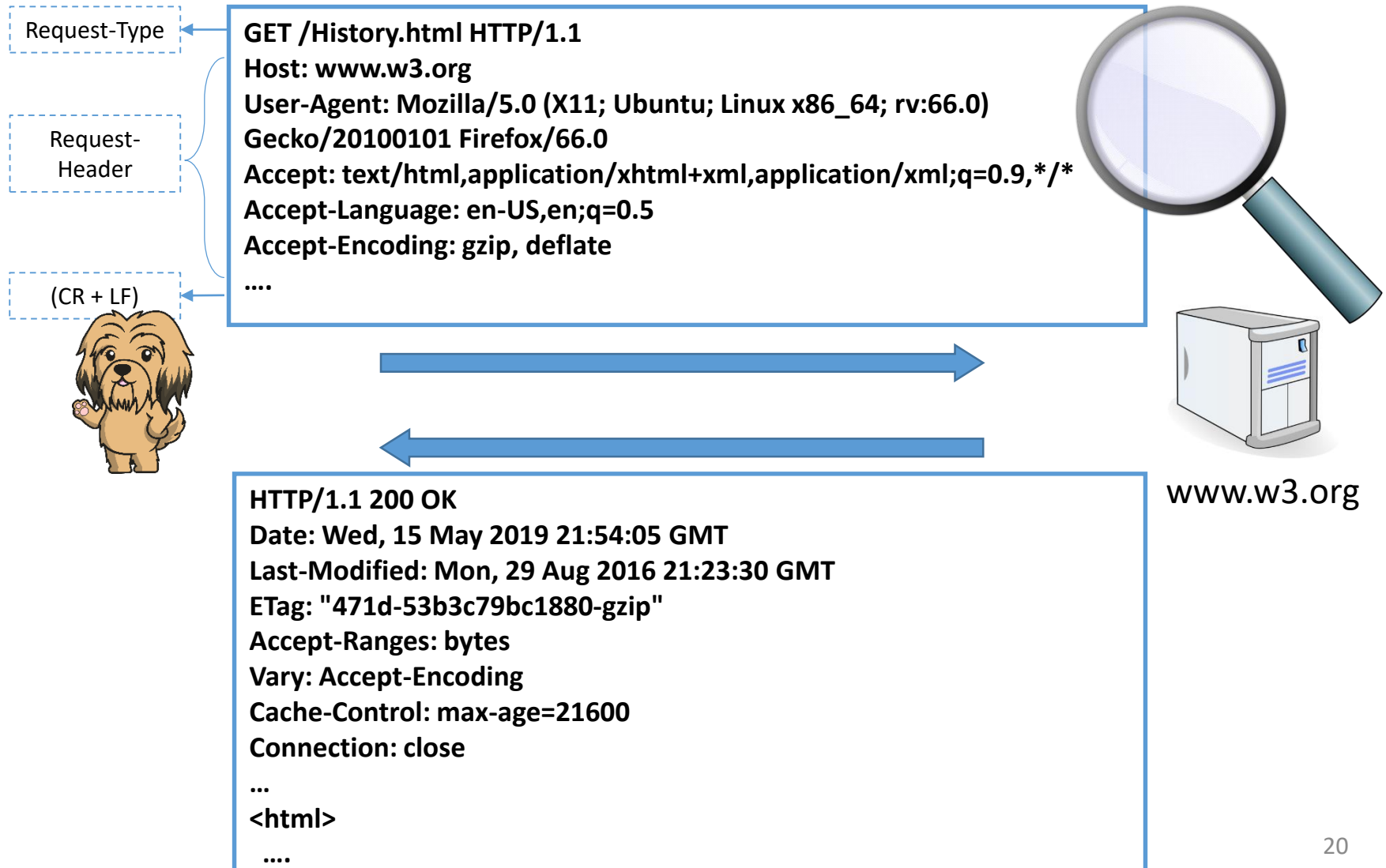
www.w3.org

```
HTTP/1.1 200 OK
Date: Wed, 15 May 2019 21:54:05 GMT
Last-Modified: Mon, 29 Aug 2016 21:23:30 GMT
ETag: "471d-53b3c79bc1880-gzip"
Accept-Ranges: bytes
Vary: Accept-Encoding
Cache-Control: max-age=21600
Connection: close
...
<html>
....
```

Hypertext Transfer Protocol

- Message Syntax and Routing ([RFC7230](#))
- Semantics and Content ([RFC7231](#))
- Conditional Requests ([RFC7232](#))
- Range Requests ([RFC7233](#))
- Caching ([RFC7234](#))
- Authentication ([RFC7235](#))

HTTP Request Header Fields



HTTP URL Scheme

- What does a URL consist of?

HTTP URL Scheme

- What does a URL consist of?

- OK, consider the following URL:

<https://google.com:microsoft.com@upb.de/example.com>

What is the domain used in this URL?

- A) google.com
- B) microsoft.com
- C) upb.de
- D) example.com
- E) The URL is invalid



<https://pingo.coactum.de/633763>

HTTP URL Scheme

- URL Scheme

- *protocol://*
 - [username:password"@"]*
 - [subdomain "."]*
 - domain-or-IP*
 - [":" port]*
 - ["/" path]*
 - ["?" paramName=paramValue"&" paramName2=paramValue2]*
 - ["#" fragment]*

- Typical usage:

- `http://a.com`
- `http://a.com:8080`
- `http://sub.a.com`
- `http://a.com/path/pathNext`
- `http://a.com?param1=value1¶m2=value2`
- `http://user:password@a.com/path`
- `http://a.com/path#section2.5`

HTTP Request Methods

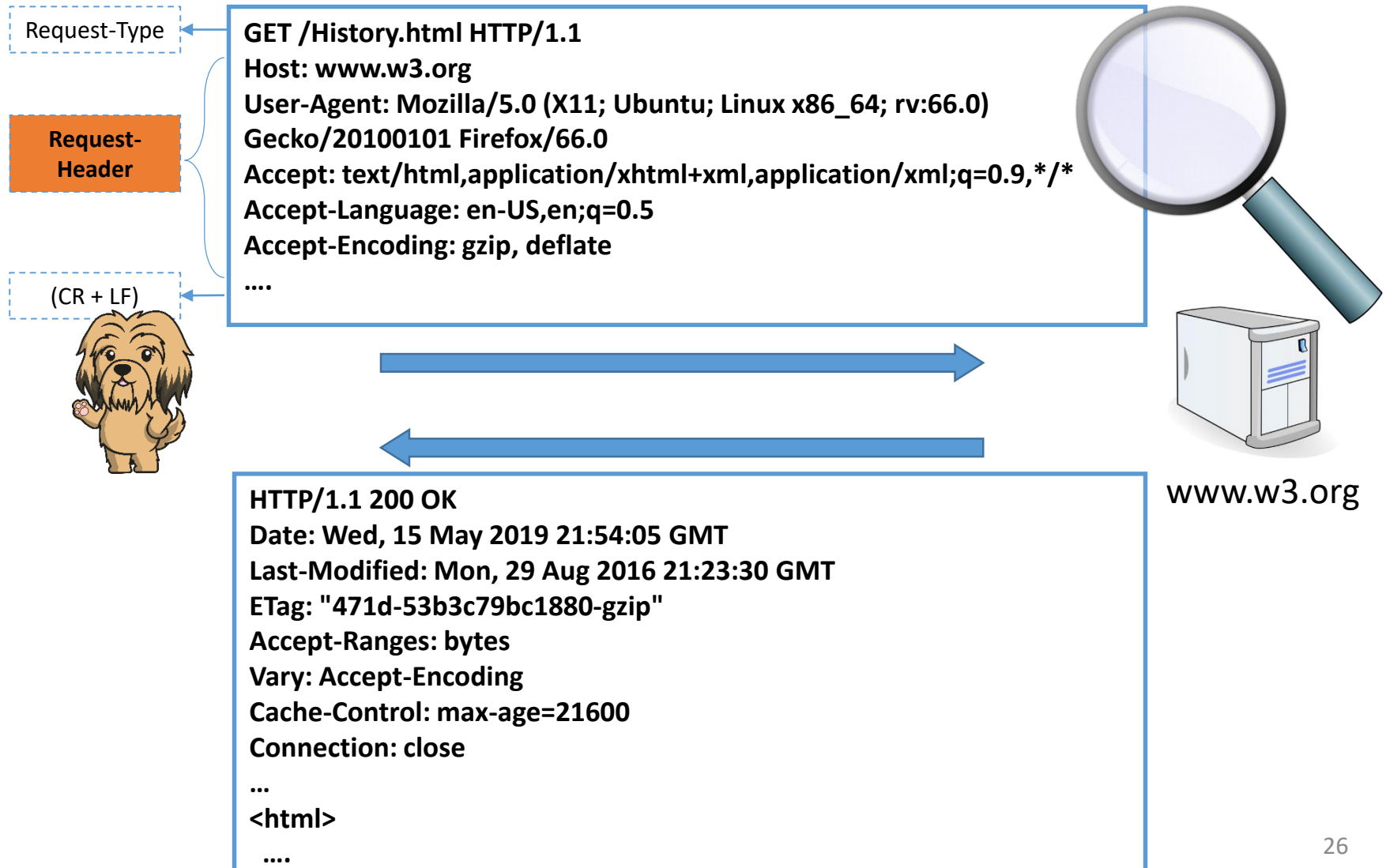
- GET:
 - Requests a representation of the specified resource. Requests using GET should only retrieve data.
- HEAD:
 - Identical to GET, but without the response body.
- POST:
 - Used to submit an entity to the specified resource. Can cause a change in state on the server.

HTTP Request Methods

- TRACE:
 - Debugging
 - Sent message is reflected
- DELETE:
 - Deletes specified resource
- PUT
- CONNECT
- OPTIONS
- PATCH

<https://developer.mozilla.org/de/docs/Web/HTTP/Methods>

HTTP Request Header Fields



HTTP Request Header Fields

- Controls Headers
- Conditions Headers
- Content Negotiation Headers
- Authentication Credentials
- Request Context

HTTP Request Header Fields

- **Content Negotiation Header**

- **Accept:** specify response media types that are acceptable
 - *E.g., Accept: audio/*; q=0.2, audio/basic*
 - *E.g., Accept: text/plain; q=0.5, text/html, text/x-dvi; q=0.8*
- **Accept-Charset:** indicate what charsets are acceptable in textual response content
 - *E.g., Accept-Charset: iso-8859-5, unicode-1-1;q=0.8*
- **Accept-Encoding:** indicate what response content-codings
 - *E.g., Accept-Encoding: compress, gzip*

Quality values,
indicate preferences
(default 1)

HTTP Request Header Fields

- Content Negotiation Header
 - **Accept-Language:**
 - *E.g., Accept-Language: de;q=0.5, en-gb;q=0.8, en;q=0.7*

What will be the website language if the Server supports German and en-US?

- A) German
- B) English (GB)
- C) English (US)
- D) The server returns a failure



<https://pingo.coactum.de/633763>

HTTP Request Header Fields

- Controls Header

- **Host:** the host and port information from the target URI
 - *E.g., Host = uri-host [":" port]*
- **Cache-Control:** specify directives for caches along the request/response chain
 - *max-age, max-stale, min-fresh, no-cache, no-store, no-transform, only-if-cached*
 - *E.g., max-age=5*
- **Expect:** indicates a certain set of behaviors
 - *E.g., Expect = "100-continue"*
- **Max-Forwards:** used with the TRACE and OPTIONS to limit the number of times that the request is forwarded by proxies
 - *E.g., Max-Forwards = 10*

The server responds with a failure if it cannot meet the expectation

HTTP Request Header Fields

- Conditions Header
 - **If-Modified-Since, If-Unmodified-Since**
 - *E.g., If-Modified-Since: Sat, 29 Oct 1994 19:43:31 GMT*
 - **IF-Match, If-None-Match**
 - *If-Match: <etag_value>, <etag_value>, ...*
 - *E.g, If-Match: "bfc13a64729c4290ef5b2c2730249c8"*
 - The server sends the resource only if it matches one of the listed Etags

Etag: entity-tag is an opaque validator for differentiating between multiple representations of the same resource

HTTP Request Header Fields

- Request Context
 - **Referer:**
 - allows the user agent to specify a URI reference for the resource from which the target URI was obtained
 - *E.g., Referer: http://www.example.org/*
 - **User-Agent:** contains information about the user agent originating the request
 - *E.g., User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:74.0) Gecko/20100101 Firefox/74.0*

HTTP Request Header Fields

- Authentication Credentials

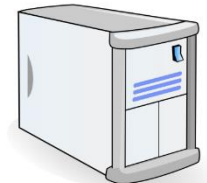
Later ...

Questions



HTTP Response Header Fields

```
GET /History.html HTTP/1.1
Host: www.w3.org
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:66.0)
Gecko/20100101 Firefox/66.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
....
```



www.w3.org

Status

```
HTTP/1.1 200 OK
Date: Wed, 15 May 2019 21:54:05 GMT
Last-Modified: Mon, 29 Aug 2016 21:23:30 GMT
ETag: "471d-53b3c79bc1880-gzip"
Accept-Ranges: bytes
Vary: Accept-Encoding
Cache-Control: max-age=21600
Connection: close
...
<html>
....
```



Response-Header

Body

HTTP Response Status Codes

- 1xx: Information responses
 - 100 Continue (Everything is ok, please continue)
- 2xx: Success
 - 200 OK
 - 201 Created (Typically after PUT requests)
- 3xx: Redirection
 - 301 Moved Permanently
 - 302 Found (Resource changed temporarily)

HTTP Response Status Codes

- 4xx: Client error responses
 - 400 Bad Request
 - 401 Unauthorized
 - 403 Forbidden
 - 404 Not Found
- 5xx: Server error responses
 - 500 Internal Server Error

HTTP Response Status



100
Continue



200
OK



202
Accepted



204
No Content



301
Moved Permanently



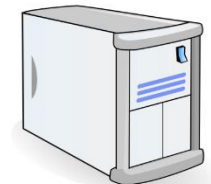
404
Not Found

HTTP Response Header Fields

- Control Data
- Validator Header Fields
- Authentication
- Response Context

HTTP Response Header Fields

```
GET /History.html HTTP/1.1
Host: www.w3.org
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:66.0)
Gecko/20100101 Firefox/66.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
....
```



www.w3.org

Status

Response-Header

Body

```
HTTP/1.1 200 OK
Date: Wed, 15 May 2019 21:54:05 GMT
Last-Modified: Mon, 29 Aug 2016 21:23:30 GMT
ETag: "471d-53b3c79bc1880-gzip"
Accept-Ranges: bytes
Vary: Accept-Encoding
Cache-Control: max-age=21600
Connection: close
...
<html>
....
```



HTTP Response Header Fields

- **Control Data**
 - **Age:** estimate of the amount of time since the response was generated
 - *E.g., Age = 360*
 - **Cache-Control:** see HTTP Requests
 - **Expires:** gives the date/time after which the response is considered stale
 - *E.g., Expires: Thu, 01 Dec 1994 16:00:00 GMT*
 - **Date:** represents the date and time at which the message was originated

HTTP Response Header Fields

- Validator Header Fields
 - **Etag**: entity-tag is an opaque validator for differentiating between multiple representations of the same resource
 - *E.g., ETag: "33a64df551425fcc55e4d42a148795d9f25f89d4"*
 - **Last-Modified**: provides a timestamp indicating the date and of the last modified

HTTP Response Header Fields

- Authentication

Later ...

HTTP Response Header Fields

- Response Context
 - **Accept-Ranges**: allows a server to indicate that it supports range requests for the target resource
 - **Allow**: lists the set of methods advertised as supported by the target resource
 - *E.g., Allow: GET, HEAD, PUT*
 - **Server**: information about the software used by the origin server to handle the request
 - *E.g., Server: CERN/3.0 libwww/2.17*

HTTP headers (about 300 ...)

Header Field Name	Template	Protocol	Status	Reference
A-IM		http		[RFC4229]
Accept		http	standard	[RFC7231, Section 5.3.2]
Accept-Additions		http		[RFC4229]
Accept-Charset		http	standard	[RFC7231, Section 5.3.3]
Accept-Datetime		http	informational	[RFC7089]
Accept-Encoding		http	standard	[RFC7231, Section 5.3.4][RFC7694, Section 3]
Accept-Features		http		[RFC4229]
Accept-Language		http	standard	[RFC7231, Section 5.3.5]
Accept-Language		mail		[RFC4021]
Accept-Patch		http		[RFC5789]
Accept-Post	perm/accept-post	http	standard	[https://www.w3.org/TR/ldp/]
Accept-Ranges		http	standard	[RFC7233, Section 2.3]
Age		http	standard	[RFC7234, Section 5.1]
Allow		http	standard	[RFC7231, Section 7.4.1]
ALPN		http	standard	[RFC7639, Section 2]
Also-Control		netnews	obsoleted	[RFC1849][RFC5536]
Alt-Svc		http	standard	[RFC7838]
Alt-Used		http	standard	[RFC7838]
Alternate-Recipient		mail		[RFC4021]
Alternates		http		[RFC4229]
Apply-To-Redirect-Ref		http		[RFC4437]
Approved		netnews	standard	[RFC5536]
ARC-Authentication-Results		mail	experimental	[RFC-ietf-dmarc-arc-protocol-23]
ARC-Message-Signature		mail	experimental	[RFC-ietf-dmarc-arc-protocol-23]
ARC-Seal		mail	experimental	[RFC-ietf-dmarc-arc-protocol-23]
Archive		netnews	standard	[RFC5536]
Archived-At		mail	standard	[RFC5064]
Archived-At		netnews	standard	[RFC5064]
Article-Names		netnews	obsoleted	[RFC1849][RFC5536]
Article-Updates		netnews	obsoleted	[RFC1849][RFC5536]
Authentication-Control		http	experimental	[RFC8053, Section 4]
Authentication-Info		http	standard	[RFC7615, Section 3]
Authentication-Results		mail	standard	[RFC-ietf-dmarc-rfc7601bis-06]
Authorization		http	standard	[RFC7235, Section 4.2]
Auto-Submitted		mail	standard	[RFC3834 section 5]
Autoforwarded		mail		[RFC4021]
Autosubmitted		mail		[RFC4021]
C-Ext		http		[RFC4229]

<https://www.iana.org/assignments/message-headers/message-headers.xhtml>

Questions



414

Request-URI Too Long

DEMO

Encodings in Web

- Motivation
 - Special Characters in GET Parameters
 - “;”, “/”, “?”, “:”, “@”, “=” and “&”
 - `http://a.com?p1=&=! &p2=value2`
 - Binary Data
- Encodings
 - URL Encoding
 - Base64 Encoding

Encodings in Web

- URL Encoding

- Special Characters

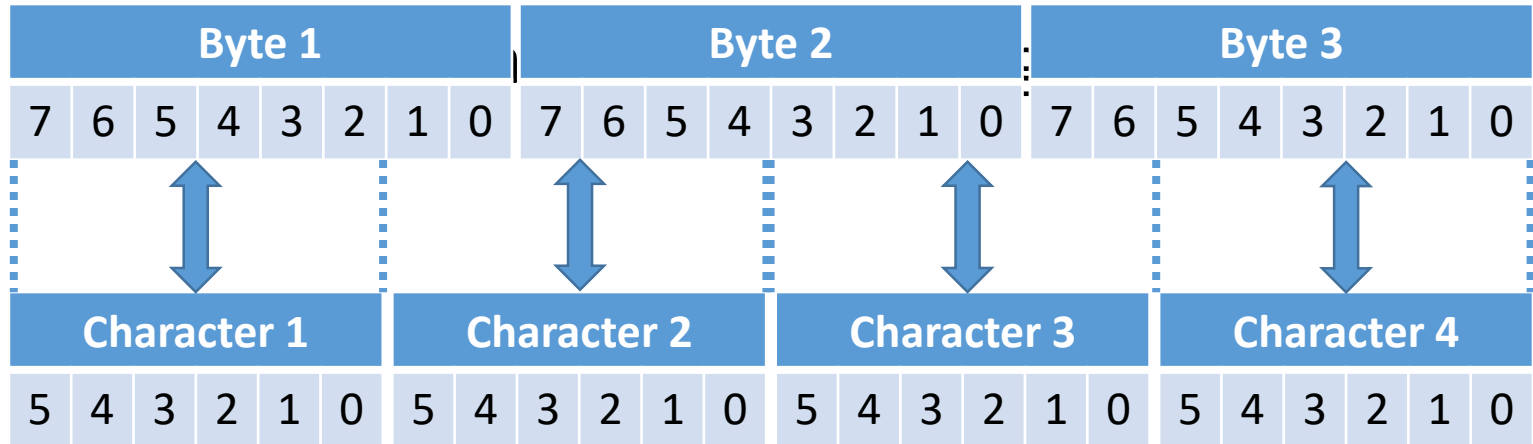
- “;” → %3B
 - “/” → %2F
 - “?” → %3F
 - “:” → %3A
 - “@” → %40
 - “=” → %3D
 - “&” → %26
 - “ ” → %20

- `http://a.com?p1=&!=`
`&p2=value2`

- `http://a.com?p1=%26%3D!%`
`20&p2=value2`

Scan-code	ASCII hex dez	Zeichen	Scan-code	ASCII hex dez	Zch.	Scan-code	ASCII hex dez	Zch.	Scan-code	ASCII hex dez	Zch.
	00 0	NUL ^@		20 32	SP		40 64	@	0D	60 96	`
	01 1	SOH ^A	02	21 33	!	1E	41 65	A	1E	61 97	a
	02 2	STX ^B	03	22 34	"	30	42 66	B	30	62 98	b
	03 3	ETX ^C	29	23 35	#	2E	43 67	C	2E	63 99	c
	04 4	EOT ^D	05	24 36	\$	20	44 68	D	20	64 100	d
	05 5	ENQ ^E	06	25 37	%	12	45 69	E	12	65 101	e
	06 6	ACK ^F	07	26 38	&	21	46 70	F	21	66 102	f
	07 7	BEL ^G	0D	27 39	'	22	47 71	G	22	67 103	g
0E	08 8	BS ^H	09	28 40	(	23	48 72	H	23	68 104	h
0F	09 9	TAB ^I	0A	29 41	)	17	49 73	I	17	69 105	i
	0A 10	LF ^J	1B	2A 42	*	24	4A 74	J	24	6A 106	j
	0B 11	VT ^K	1B	2B 43	+	25	4B 75	K	25	6B 107	k
	0C 12	FF ^L	33	2C 44	,	26	4C 76	L	26	6C 108	l
1C	0D 13	CR ^M	35	2D 45	-	32	4D 77	M	32	6D 109	m
	0E 14	SO ^N	34	2E 46	.	31	4E 78	N	31	6E 110	n
	0F 15	SI ^O	08	2F 47	/	18	4F 79	O	18	6F 111	o
	10 16	DLE ^P	0B	30 48	0	19	50 80	P	19	70 112	p
	11 17	DC1 ^Q	02	31 49	1	10	51 81	Q	10	71 113	q
	12 18	DC2 ^R	03	32 50	2	13	52 82	R	13	72 114	r
	13 19	DC3 ^S	04	33 51	3	1F	53 83	S	1F	73 115	s
	14 20	DC4 ^T	05	34 52	4	14	54 84	T	14	74 116	t
	15 21	NAK ^U	06	35 53	5	16	55 85	U	16	75 117	u
	16 22	SYN ^V	07	36 54	6	2F	56 86	V	2F	76 118	v
	17 23	ETB ^W	08	37 55	7	11	57 87	W	11	77 119	w
	18 24	CAN ^X	09	38 56	8	2D	58 88	X	2D	78 120	x
	19 25	EM ^Y	0A	39 57	9	2C	59 89	Y	2C	79 121	y
	1A 26	SUB ^Z	34	3A 58	:	15	5A 90	Z	15	7A 122	z
01	1B 27	Esc ^[	33	3B 59	;		5B 91	[		7B 123	{
	1C 28	FS ^\	2B	3C 60	<		5C 92	\		7C 124	
	1D 29	GS ^]	0B	3D 61	=		5D 93	]		7D 125	}
	1E 30	RS ^^	2B	3E 62	>	29	5E 94	^		7E 126	~
	1F 31	US ^_	0C	3F 63	?	35	5F 95	_	53	7F 127	DEL

Base64

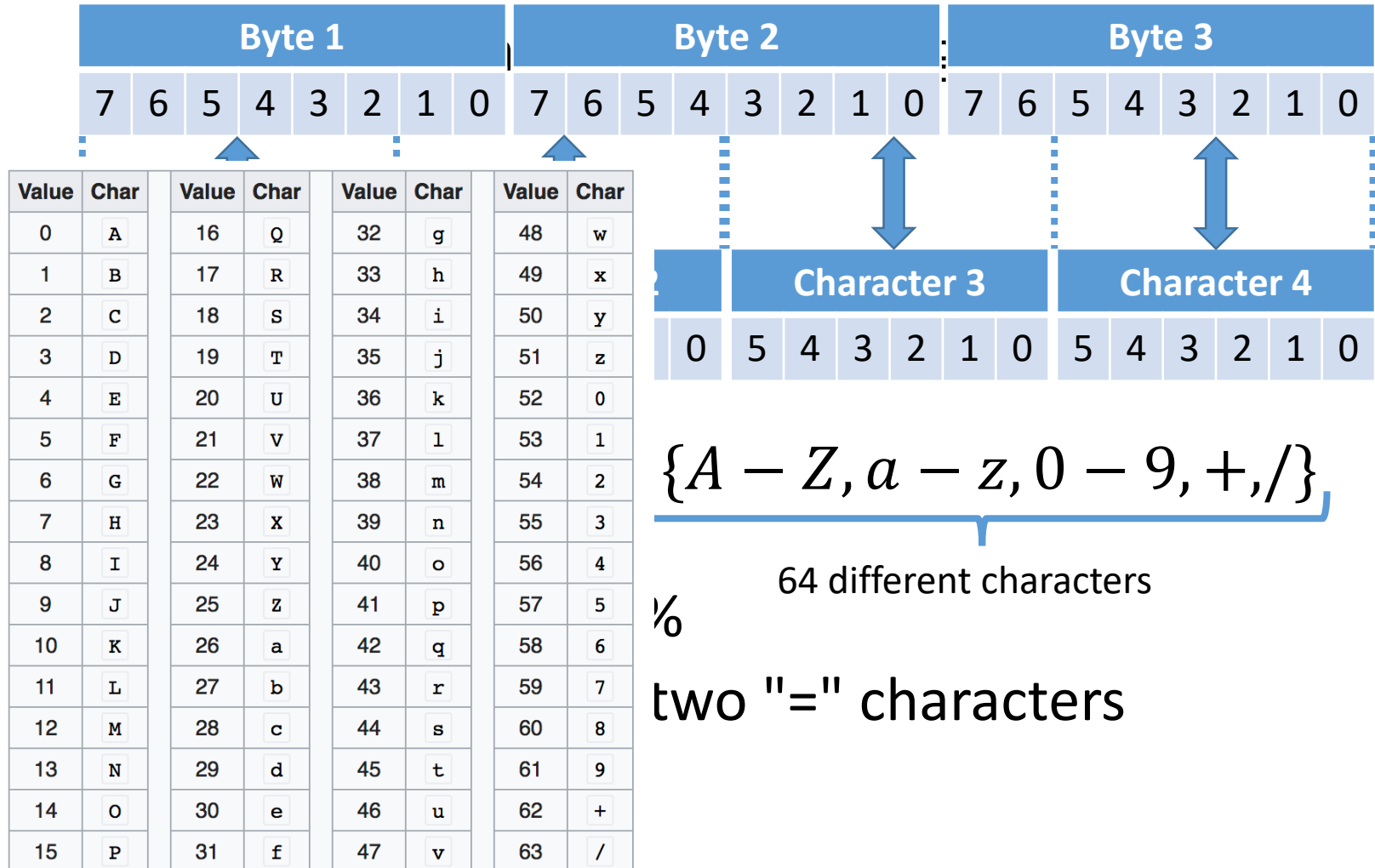


- $3 \cdot \{0, \dots, 255\} \mapsto 4 \cdot \underbrace{\{A - Z, a - z, 0 - 9, +, /\}}_{64 \text{ different characters}}$

64 different characters

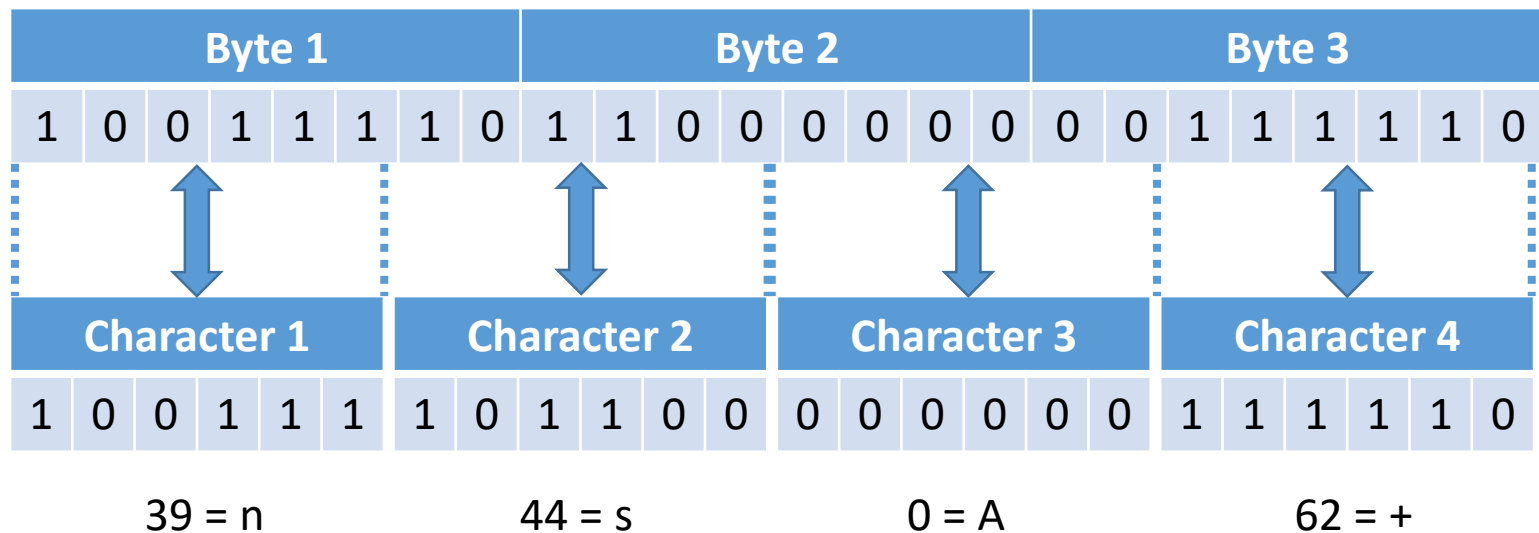
- Data expansion: ~33%
- Padding with one or two "=" characters

Base64



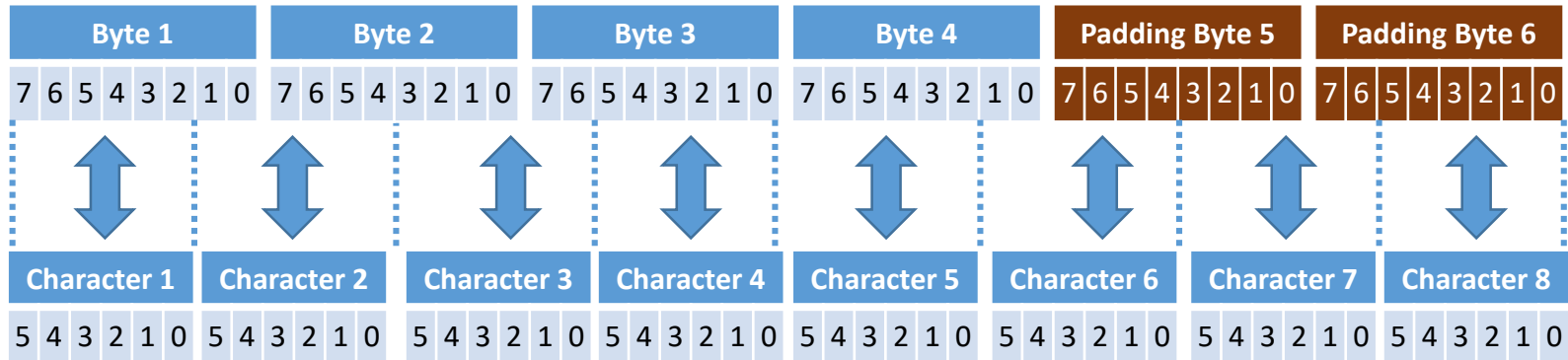
Base64 example

Value	Char	Value	Char	Value	Char	Value	Char
0	A	16	Q	32	g	48	w
1	B	17	R	33	h	49	x
2	C	18	S	34	i	50	y
3	D	19	T	35	j	51	z
4	E	20	U	36	k	52	0
5	F	21	V	37	l	53	1
6	G	22	W	38	m	54	2
7	H	23	X	39	n	55	3
8	I	24	Y	40	o	56	4
9	J	25	Z	41	p	57	5
10	K	26	a	42	q	58	6
11	L	27	b	43	r	59	7
12	M	28	c	44	s	60	8
13	N	29	d	45	t	61	9
14	O	30	e	46	u	62	+
15	P	31	f	47	v	63	/



$$\text{Base64Decode}(nsA+) = 10011110\ 11000000\ 00111110$$

Base64 with Padding



Padding with one or two "=" characters?

Questions

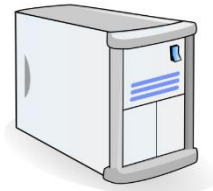


100

Continue

Authentication in Web

- HTTP Basic ([RFC7617](#))



www.w3.org

1. HTTP GET index.html

2. HTTP/1.1 401 Authorization Required

WWW-Authenticate: Basic realm="name"

Base64(admin:secure
Password)

3. HTTP GET index.html

Authorization: Basic YWRtaW46c2VjdXJlUGFzc3dvcmQ=

4. HTTP/1.0 200 OK

index.html

5. HTTP GET aboutUs.html

Authorization: Basic YWRtaW46c2VjdXJlUGFzc3dvcmQ=

...

Authentication in Web

- HTTP Form Based Authentication

```
<html>
  <head>
    <title>Form-based Authentication</title>
  </head>
  <body>
    <form action="http://bank.de" method="POST">
      <p>Username:<br></p>
      <input name="username" type="text" size="30">
      <p>Password:<br></p>
      <input name="password" type="password" size="30">
      <input type="submit" value="LogIn">
    </form>
  </body>
</html>
```

Username:

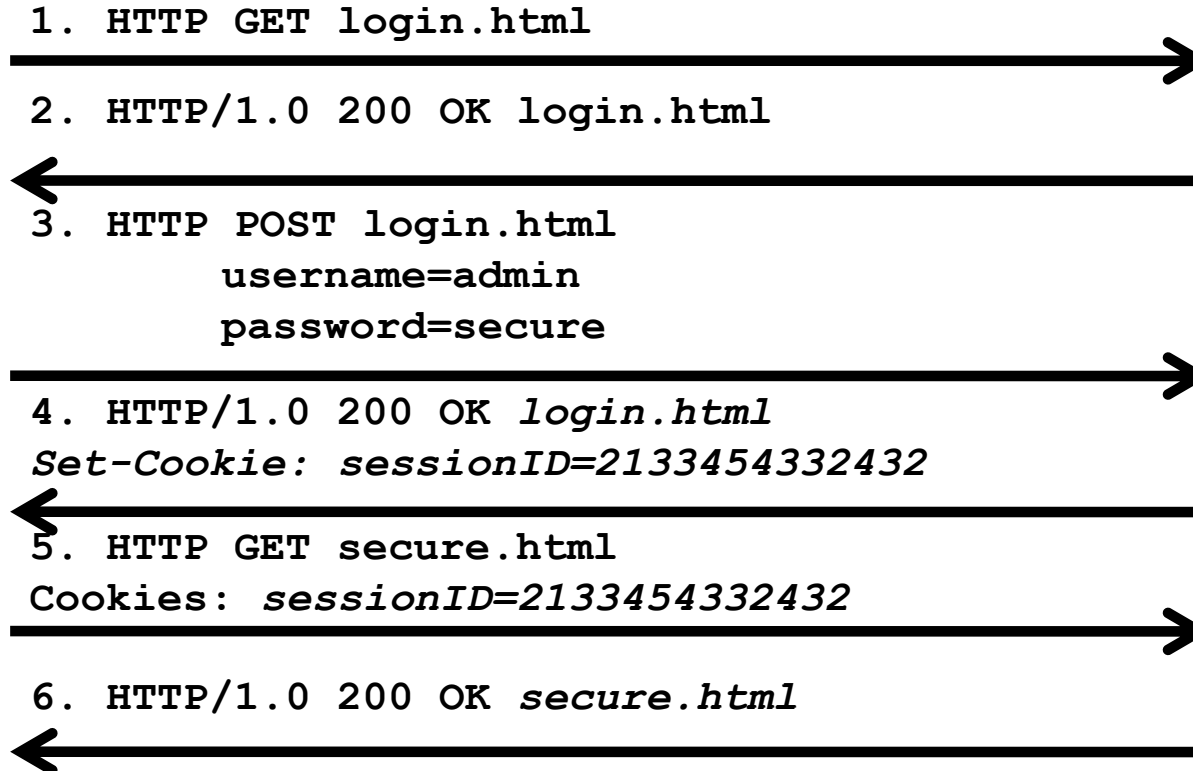
Password:

Log In

Authentication in Web



- HTTP Cookies



HTTP Cookies are important

- Risks
 - Cookies represent user's identity
 - Attackers possessing the cookie can impersonate the user
 - Cookies must be transmitted over secure channels
 - They are nearly as important as passwords
- Attacks like Cross-Site Scripting/Cross Site Request Forgery must be considered

Conclusions

- Learned basics behind HTTP
- Showed some useful analysis tools
- In two weeks:
 - HTML
 - JavaScript
 - DOM
 - Same Origin Policy

Questions



201

Created

Sources

- Hypertext Transfer Protocol (HTTP/1.1): Message Syntax and Routing ([RFC7230](#))
- Hypertext Transfer Protocol (HTTP/1.1): Semantics and Content ([RFC7231](#))
- Hypertext Transfer Protocol (HTTP/1.1): Conditional Requests ([RFC7232](#))
- Hypertext Transfer Protocol (HTTP/1.1): Range Requests ([RFC7233](#))
- Hypertext Transfer Protocol (HTTP/1.1): Caching ([RFC7234](#))
- Hypertext Transfer Protocol (HTTP/1.1): Authentication ([RFC7235](#))
- <https://developer.mozilla.org/de/docs/Web/HTTP/Methods>

Acknowledgements

- Ömmes pictures by Janine.Plickert@rub.de



- Tessa pictures by https://www.fiverr.com/tnhs_project



- This is collaborative work with Juraj Somorovsky, Tibor Jager, Andreas Mayer, Christian Mainka, Jörg Schwenk, Marcus Brinkmann, and Vladislav Mladenov